

Pre-Shared Key Attacks

Ryan Tolboom

New Jersey Institute of Technology

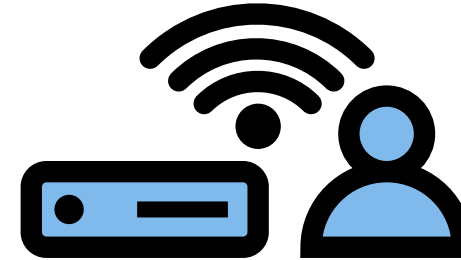


Pre-shared Key vs Enterprise



PSK

- Easy setup
- One password for everyone
- Usually used in homes
- Hard to revoke access



Enterprise

- [RADIUS authentication](#)
- Harder to set up
- Usually used in businesses
- Easy to revoke access

WEP

The screenshot shows a web-based configuration interface for wireless security. The top navigation bar includes tabs for 'Setup', 'Wireless', 'Security', 'Applications & Gaming', and 'Administration'. Under the 'Wireless' tab, there are sub-tabs for 'Basic Wireless Settings', 'Wireless Security', and 'Wireless Network'. The 'Wireless Security' sub-tab is active. The main content area displays the following settings:

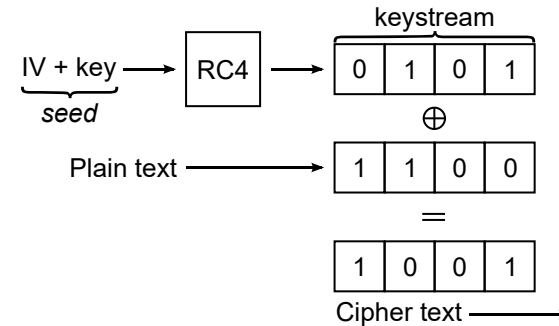
- Wireless Security:** ☒ Enable ☐ Disable
- Security Mode:** WEP (dropdown menu)
- Default Key:** ☒ 1 ☐ 2 ☐ 3 ☐ 4
- Wireless Encryption Level:** 64 bits 10 hex digits (dropdown menu)
- Passphrase:** Boris (text input)
- WEP Key 1:** EB9549486A (text input)
- WEP Key 2:** 559500AE8A (text input)
- WEP Key 3:** 32B2393E53 (text input)
- WEP Key 4:** D679BA7012 (text input)

["Hex equivalents for WEP passphrase"](#) by [Wesley Fryer](#) is licensed under [CC BY-SA 2.0](#)

- Wireless Equivalent Privacy (WEP)
- Uses RC4, a broken cipher
- Uses initialization vectors and PSK to initialize RC4
- IV are transmitted in plaintext and *may* leak information about the PSK

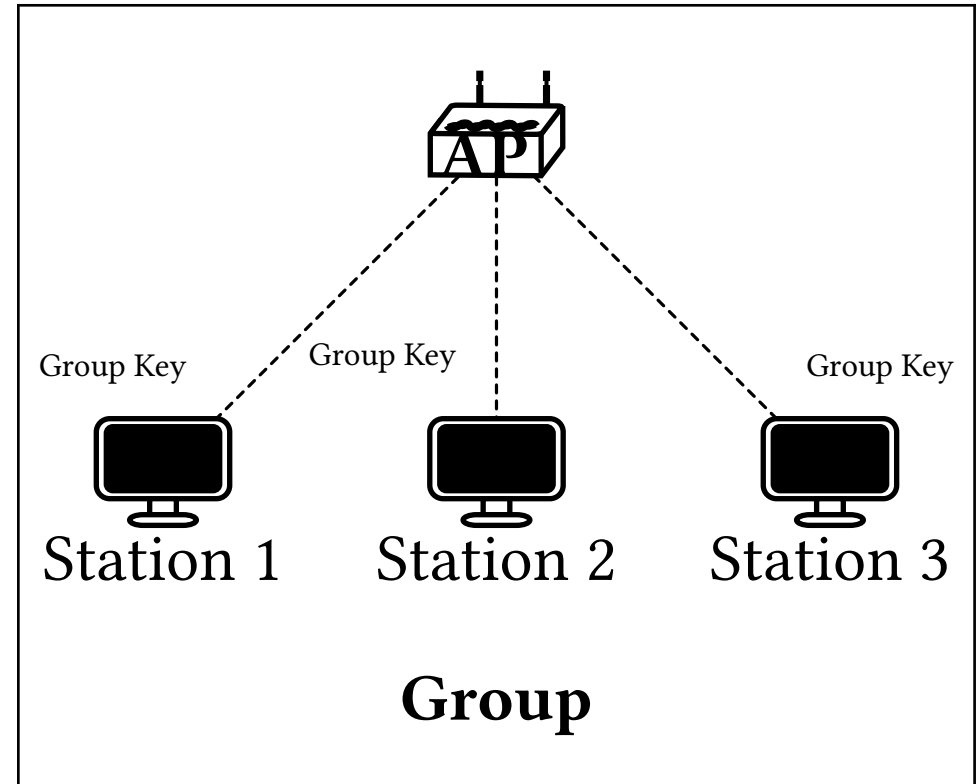
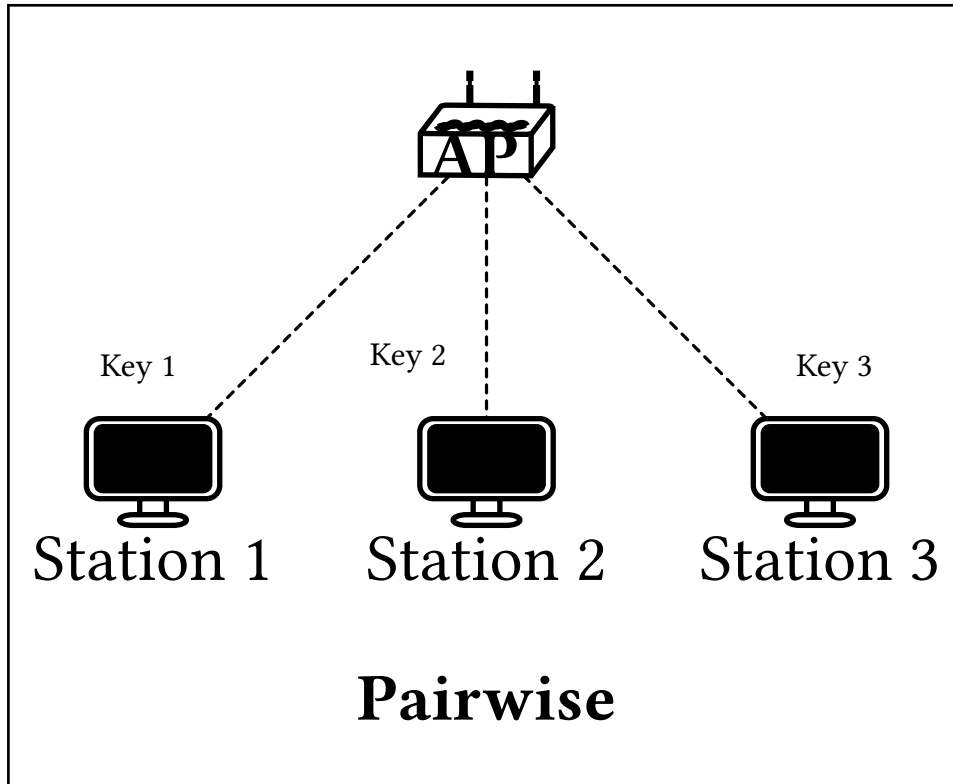
RC4, WEP, and Weak IVs

- Subnet Access Protocol (SNAP) headers are usually encrypted (IP and ARP traffic), they all start with 0xAA
- With the cipher text and the plain text you can get the key stream
- With the IV (transmitted plaintext) and key stream you may be able to get part of the key if the IV is weak
- IVs are 24 bits and repeat after about 5000 frames, which makes things easier
- With enough frames and you can crack the WEP key

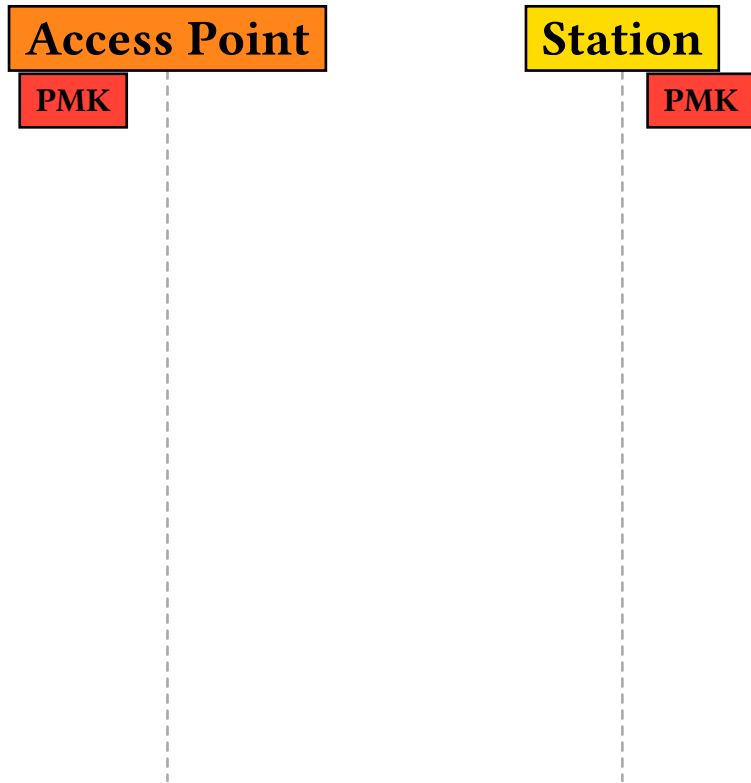


[“Basic WEP Encryption: RC4 keystream XORed with plaintext”](#) by [Stannered](#) is licensed under [CC BY-SA 3.0](#)

Pairwise vs Group Keys in WPA

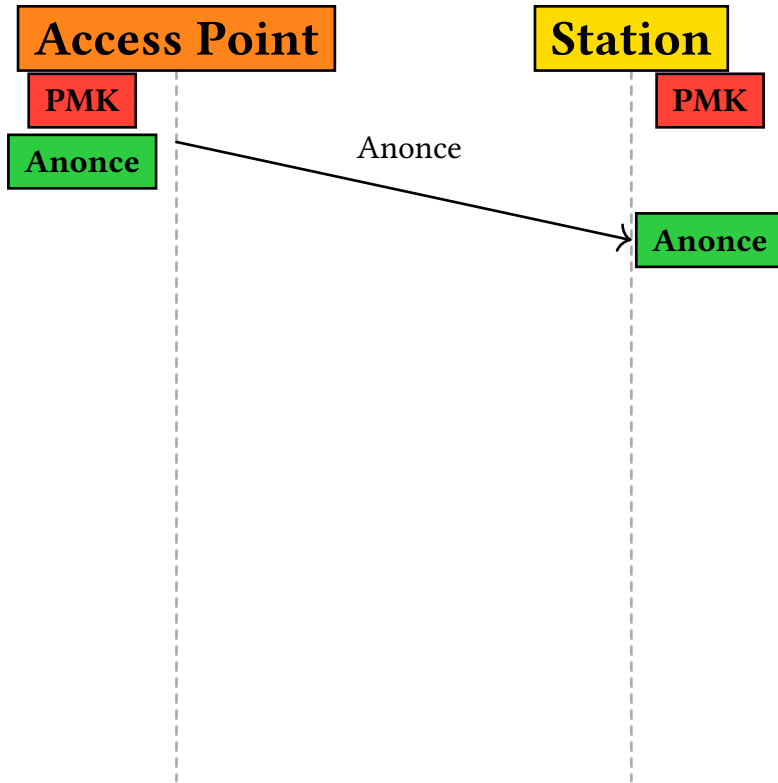


WPA2-Personal (PSK) 4-Way Handshake



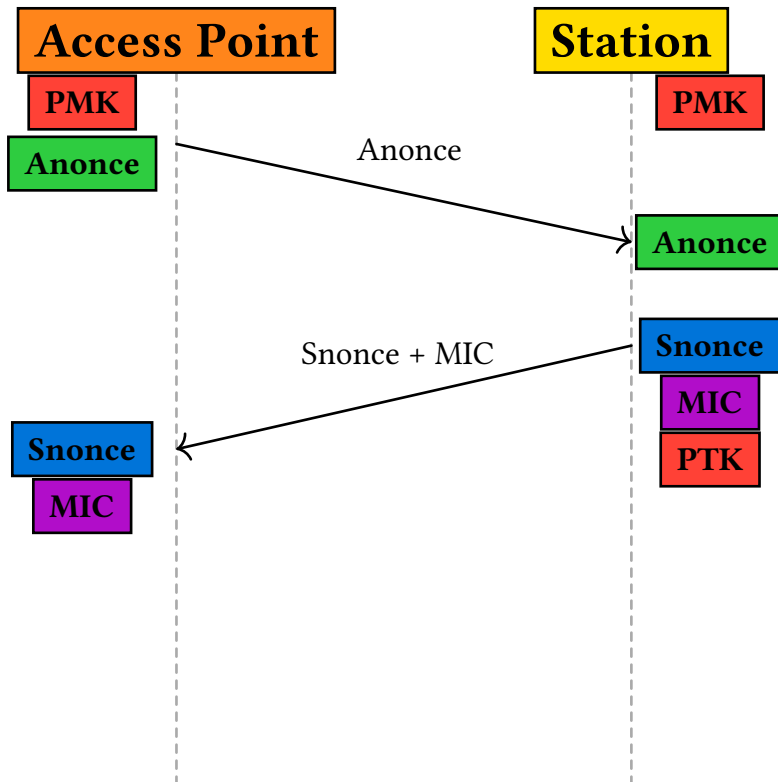
- Mostly *unencrypted* EAPOL-Key frames (Extensible Authentication Protocol over LAN)
- Starts after the station completes the association phase
- Everyone has the Pairwise Master Key (PMK) (built from the passphrase and SSID)

WPA2-Personal (PSK) 4-Way Handshake



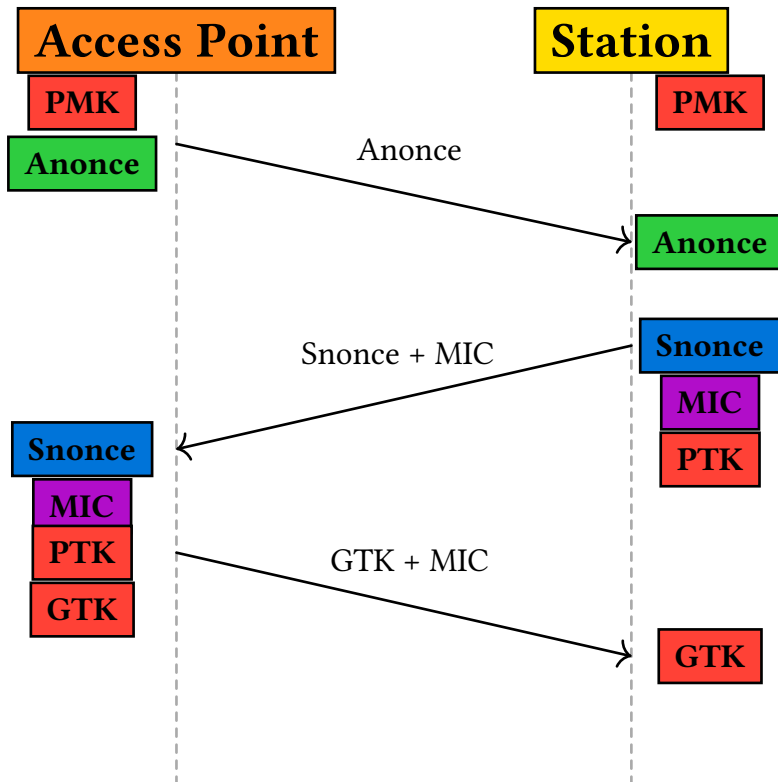
- AP generates Anonce and sends it
- Anonce is a random 256 bit number

WPA2-Personal (PSK) 4-Way Handshake



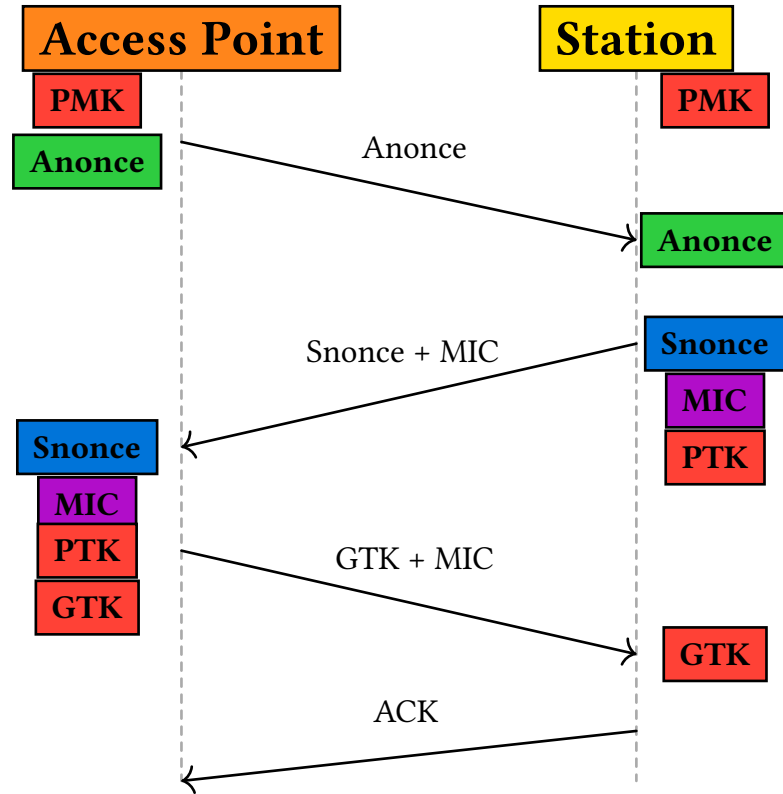
- Station generates Snonce
- Station derives Pairwise Temporal Key (PTK) from PMK, ANonce, SNonce, and MAC addresses
- Station generates Message Integrity Check (MIC) from MAC addresses, ANonce, SNonce, and PMK
- The MIC *does not* contain the PMK but you can only get it right if you have the PMK
- Station sends Snonce and MIC *unencrypted*

WPA2-Personal (PSK) 4-Way Handshake



- AP generates and compares MICs
- AP derives PTK from PMK, ANonce, SNonce, and MAC addresses
- AP sends key installation request, MIC, and current Group Temporal Key (GTK)
- Stations all use a GTK for multicast traffic
- The GTK is encrypted with the derived PTK!

WPA2-Personal (PSK) 4-Way Handshake



- Station installs keys and acknowledges